

# Problemstellung

Wir designen die Lagerverwaltung eines Großhändlers. Der Großhändler besitzt mehrere Lager. Wir wollen sowohl eine zentrale Bestandsaufnahme als auch eine Bestandsaufnahme an jedem Standort, so dass die Systeme autark funktionieren können.

Zentral soll nur gespeichert werden, wie viele Gegenstände von welcher Art an welchem Standort vorhanden sind.

In jedem Standort soll außerdem die Position des Gegenstandes im Lager angezeigt werden. Es kann davon ausgegangen werden, dass jedes Lager die gleiche Struktur hat.

Das System soll die Möglichkeit haben, anfragen bearbeiten zu können, es sollen also Gegenstände eingelagert, ausgelagert und angezeigt werden können. Falls ein Gegenstand nicht verfügbar ist, soll an anderen Standorten angefragt werden.

Weiterhin soll jeder Zugriff und jede Entnahme von Gegenständen gespeichert werden. Weiterhin soll es die Möglichkeit geben, automatisch Auswertungen einzelner Artikel zu erstellen: Wie viele Verkäufe, etc. Das System soll dann in der Lage sein, Artikel, die nicht häufig angefragt werden, nicht mehr an allen Standorten vorzuhalten oder zu entscheiden, dass ein Artikel an mehreren Standorten vorgehalten werden soll. Hierzu soll es die passende Abteilung per Email informieren oder automatisch für andere Standorte zu bestellen.

Gegenstände können ein Verfallsdatum haben.

Weiterhin soll es die Möglichkeit geben, automatisch neue Waren zu bestellen. Hierzu muss bekannt sein, wo diese bestellt werden können, und wann dies erfolgen soll.

## Pflichtenheft / Problemanalyse

Da die aktuelle Problemstellung noch viel Raum für Interpretation lässt, muss nun genau definiert werden welche Features und in welcher Form implementiert werden sollen.

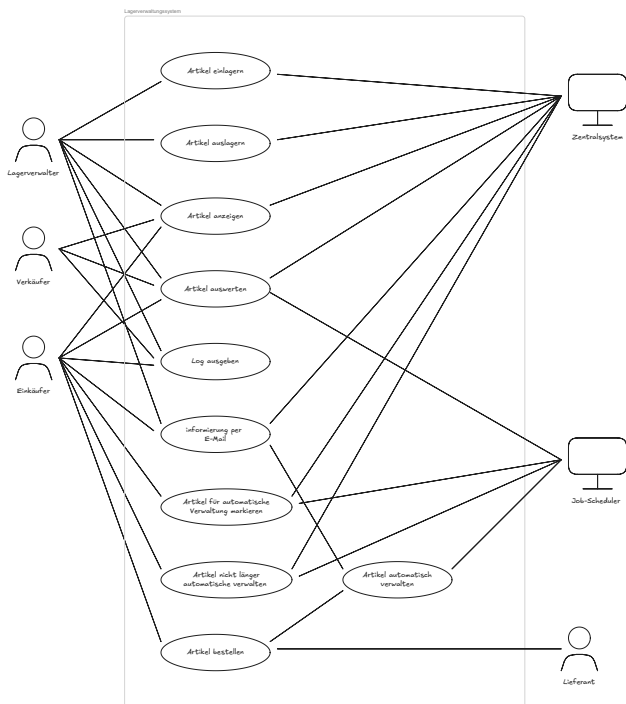
Hierzu wird nach dem Schema der Vorlesung "Objektorientierte Analyse" das Problem genauer beschrieben:

- Als erstes werden die Handlungsträger/Akteure identifiziert.
- Dann wird erkannt wie diese Zusammen interagieren.
- Daraus werden Szenarien gebildet und möglichst präzise, mit Alternativen und Fehlersituationen, beschrieben

## Akteure

1. LV - **Lagerverwalter** – Verwaltet lokalen Lagerbestand, Ein-/Auslagerungen
2. EK - **Einkäufer** – Erhält Bestellvorschläge, bestellt bei Lieferanten
3. VK - **Verkäufer** – Fragt Artikel an, löst Auslagerungen aus
4. L - **Lieferant**
5. Z - **Zentralsystem**
6. JS - **Job-Scheduler**

## Darstellung der Akteure und Anwendungsfälle



## Anwendungsfälle / Szenarien

### Artikel anzeigen

|      | Anwendungsfall               | Artikel anzeigen                                                                                                                                                                                       |
|------|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      | Kurzbeschreibung             | Jeder Akteur kann sich Details zu den Artikeln anzeigen lassen                                                                                                                                         |
|      | Beteiligte Akteure           | Lagerverwalter / Einkäufer / Verkäufer, System                                                                                                                                                         |
|      | Vorbedingung                 | Artikelnummer oder Artikelname bekannt                                                                                                                                                                 |
|      | Nachbedingung                | Allgemeine Artikelinformationen, sowie die letzten Änderungsprotokolle werden angezeigt                                                                                                                |
|      | Auslöser                     | Anfrage durch einen Akteur (LV, EK, VK)                                                                                                                                                                |
|      | <b>Standardszenario</b>      |                                                                                                                                                                                                        |
| 1    | LV                           | Lagerverwalter gibt Artikelnummer ein                                                                                                                                                                  |
| 2    | LV                           | dem Lagerverwalter werden allgemeine Artikelinformationen, lokale Bestände und deren Lagerpositionen und Änderungsprotokolle angezeigt                                                                 |
|      | <b>Alternative Szenarien</b> |                                                                                                                                                                                                        |
| zu 1 | LV                           | Lagerverwalter scannt Barcode ein                                                                                                                                                                      |
| zu 1 | EK                           | Einkäufer gibt Artikelnummer ein                                                                                                                                                                       |
| zu 1 | VK                           | Verkäufer gibt Artikelnummer ein                                                                                                                                                                       |
|      | <b>Erweiterung</b>           |                                                                                                                                                                                                        |
| zu 1 | LV / EK / VK                 | Es wird der Artikelname eingegeben;<br>Es wird eine Liste mit den wahrscheinlichsten Treffern und deren Artikelnummern angezeigt;<br>Durch Auswahl eines Eintrags wird diese Artikelnummer eingegeben. |
|      | <b>Fehlersituationen</b>     |                                                                                                                                                                                                        |
| zu 1 | LV                           | Artikelnummer existiert nicht; Vorgang wird abgebrochen                                                                                                                                                |

### Artikel einlagern

|      |                              |                                                                                                                                                     |
|------|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
|      | <b>Anwendungsfall</b>        | <b>Artikel einlagern</b>                                                                                                                            |
|      | Kurzbeschreibung             | Der Lagerverwalter kann Lagerartikel im System erfassen. Dabei bekommt er einen Lagerplatz vom System vorgeschlagen, kann aber einen definieren     |
|      | Beteiligte Akteure           | Lagerverwalter, Zentralsystem                                                                                                                       |
|      | Vorbedingung                 | Artikel ist am Standort eingetroffen, Artikelnummer ist bekannt                                                                                     |
|      | Nachbedingung                | Artikel im System erfasst, Lagerposition zugewiesen, Lagerbestand aktualisiert, Änderung protokolliert, Zentrallagerbestand aktualisiert            |
|      | Auslöser                     | Artikel müssen eingelagert werden.<br>- Anlieferung neuer Ware<br>- Auftragsstornierung und wieder-Einlagerung<br>- etc.                            |
|      | <b>Standardszenario</b>      |                                                                                                                                                     |
| 1    | LV                           | Lagerverwalter gibt Artikelnummer ein                                                                                                               |
| 2    | LV                           | Dem Lagerverwalter werden Allgemeine Artikelinformationen angezeigt                                                                                 |
| 3    | LV                           | Lagerverwalter trägt Lagerposition und Menge ein                                                                                                    |
| 4    | Z                            | Informierung des Zentralsystem über Bestandsaktualisierung, mit Artikelnummer und hinzugefügter Stückzahl                                           |
| 5    | Z                            | Zentralsystem aktualisiert Gesamtbestand und erstellt eigens Protokoll zu: Mengenänderung und Standort der Änderung                                 |
|      | <b>Alternative Szenarien</b> |                                                                                                                                                     |
| zu 1 | LV                           | Lagerverwalter scannt Barcode ein                                                                                                                   |
| zu 3 | LV                           | Lagerverwalter bestätigt die vom System vorgeschlagene Lagerposition                                                                                |
|      | <b>Erweiterungen</b>         |                                                                                                                                                     |
| zu 3 | LV                           | Lagerverwalter trägt zusätzliche ein Verfallsdatum ein;<br>System speichert Artikel mit Position, Stückzahl und Verfallsdatum                       |
| zu 4 | Z                            | Es existieren noch markierte Änderungen, die noch gesendet werden müssen;<br>Zentralsystem wird über alle unsynchronisierten Änderungen informiert; |
|      | <b>Fehlersituationen</b>     |                                                                                                                                                     |
| zu 1 | LV                           | eingetragene Artikelnummer nicht vorhanden; Anwendungsfall wird abgebrochen                                                                         |
| zu 4 | Z                            | Zentralsystem nicht erreichbar;<br>Änderungen bleiben lokal gespeichert und für spätere Synchronisierung markiert                                   |

## Artikel auslagern

|  |                       |                                                                                                                                                                                                                    |
|--|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <b>Anwendungsfall</b> | <b>Artikel auslagern</b>                                                                                                                                                                                           |
|  | Kurzbeschreibung      | Der Lagerverwalter kann Artikel auslagern. Dabei kann er entscheiden, welche Position im Lager ausgelagert wird.<br>Es werden die Bestände der anderen Standorten angezeigt.                                       |
|  | Beteiligte Akteure    | Lagerverwalter, Zentralsystem                                                                                                                                                                                      |
|  | Vorbedingung          | Artikelnummer bekannt, Artikelbestand > 0                                                                                                                                                                          |
|  | Nachbedingung         | Bestand an Lagerposition aktualisiert, Änderung protokolliert, Zentrallagerbestand aktualisiert                                                                                                                    |
|  | Auslöser              | Artikel muss ausgelagert werden.<br>- Verkauf getätigt und Ware muss für den Versand aus dem Lager.<br>- Ware ist abgelaufen und muss entsorgt.<br>- Ware muss zur Weiterverarbeitung in die Produktion.<br>- etc. |

|      | Anwendungsfall               | Artikel auslagern                                                                                                                                                              |
|------|------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      | <b>Standardszenario</b>      |                                                                                                                                                                                |
| 1    | LV                           | Lagerverwalter gibt Artikelnummer ein                                                                                                                                          |
| 2    | LV                           | Dem Lagerverwalter werden alle Im lokalen Standort vorhandenen Lagerpositionen und deren Verfallsdaten angezeigt. Separat werden die Bestände in anderen Standorten angezeigt. |
| 3    | LV                           | Lagerverwalter wählt Position aus und gibt auszulagernde Menge an                                                                                                              |
| 4    | Z                            | System sendet Bestandsaktualisierung, mit Artikelnummer und entnommener Stückzahl an Zentralsystem                                                                             |
| 7    | Z                            | Zentralsystem aktualisiert Gesamtbestand und erstellt eigens Protokoll zu: Mengenänderung und Standort der Änderung                                                            |
|      | <b>Alternative Szenarien</b> |                                                                                                                                                                                |
| zu 1 | LV                           | Lagerverwalter scannt Barcode ein                                                                                                                                              |
|      | <b>Erweiterungen</b>         |                                                                                                                                                                                |
| zu 4 | Z                            | Es existieren noch markierte Änderungen, die noch gesendet werden müssen; Zentralsystem wird über alle unsynchronisierten Änderungen informiert;                               |
|      | <b>Fehlersituationen</b>     |                                                                                                                                                                                |
| zu 1 | LV                           | eingetragene Artikelnummer nicht vorhanden; Anwendungsfall wird abgebrochen                                                                                                    |
| zu 3 | LV                           | auszulagernde Menge größer als Position; Anwendungsfall wird abgebrochen                                                                                                       |
| zu 4 | Z                            | Zentralsystem nicht erreichbar; Änderungen bleiben lokal gespeichert und für spätere Synchronisierung markiert                                                                 |

## Artikel auswerten

|      | Anwendungsfall               | Artikel auswerten                                                                                                                                                                                                                                                                                                                        |
|------|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      | Kurzbeschreibung             | Jeder Akteur kann Auswertungen zu einem Artikel erstellen lassen, um Informationen über globale Bestände zu erhalten                                                                                                                                                                                                                     |
|      | Beteiligte Akteure           | Lagerverwalter / Einkäufer / Verkäufer / Job-Scheduler, Zentralsystem                                                                                                                                                                                                                                                                    |
|      | Vorbedingung                 | Artikelnummer bekannt                                                                                                                                                                                                                                                                                                                    |
|      | Nachbedingung                | globale Menge und die Verteilung dieser über die Standorte werden angezeigt. Statistiken zu globalen und lokalen Verkaufszahlen werden angezeigt                                                                                                                                                                                         |
|      | Auslöser                     | <ul style="list-style-type: none"> <li>- Einkauf will indizieren, ob eine Bestellung ausgelöst werden sollte oder ob es sich überhaupt lohnt diesen Artikel weiter zu führen.</li> <li>- Lagerverwalter will entscheiden, ob er gewisse Artikel sehr erreichbar oder eher schwer erreichbar einlagern sollte.</li> <li>- etc.</li> </ul> |
|      | <b>Standardszenario</b>      |                                                                                                                                                                                                                                                                                                                                          |
| 1    | LV                           | Lagerverwalter gibt Artikelnummer ein                                                                                                                                                                                                                                                                                                    |
| 2    | Z                            | Beim Zentralsystem werden globale Bestände und globale Statistiken angefordert                                                                                                                                                                                                                                                           |
| 3    | Z                            | Zentralsystem berechnet globale Statistiken zu Standortbezogenen Aus- und Einlagerungen, sowie aktuellen Beständen und gibt diese zurück                                                                                                                                                                                                 |
| 4    | LV                           | dem Lagerverwalter werden lokale / globale Bestände und ihre Verteilung über die Standorte und die Statistiken zu Standortbezogenen Aus- und Einlagerungen an.                                                                                                                                                                           |
|      | <b>Alternative Szenarien</b> |                                                                                                                                                                                                                                                                                                                                          |
| zu 1 | LV                           | Lagerverwalter scannt Barcode ein                                                                                                                                                                                                                                                                                                        |
| zu 1 | EK                           | Einkäufer gibt Artikelnummer ein                                                                                                                                                                                                                                                                                                         |

|      | Anwendungsfall    | Artikel auswerten                                                                                                                                                                                                                                |
|------|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| zu 1 | VK                | Verkäufer gibt Artikelnummer ein                                                                                                                                                                                                                 |
| zu 1 | JS                | Job-Scheduler löst Routineauswertung aus                                                                                                                                                                                                         |
| zu 3 | Z                 | Zentralsystem merkt, dass seit der letzten Statistikberechnung keine Änderung vorgenommen worden ist und gibt die letzte Berechnung zurück                                                                                                       |
|      | Erweiterungen     |                                                                                                                                                                                                                                                  |
| zu 4 | Z                 | Zentralsystem erkennt, dass Standortbezogener Lagerbestand unter Mindestbestand liegt;<br>System informiert zuständigen Einkauf per E-Mail                                                                                                       |
| zu 4 | Z                 | Zentralsystem erkennt, dass Standortbezogener Lagerbestand unter Mindestbestand liegt und der Artikel für automatischen Einkauf markiert ist;<br>System löst statistisch empfohlene Bestellung aus und informiert zuständigen Einkauf per E-Mail |
|      | Fehlersituationen |                                                                                                                                                                                                                                                  |
| zu 1 | LV                | Artikelnummer existiert nicht; Vorgang wird abgebrochen                                                                                                                                                                                          |
| zu 3 | Z                 | Zentralsystem merkt, dass eine Verbindung zu einem Standort nicht herrscht und gibt Warnmeldung zu dieser Standortbezogenen Statistik zurück                                                                                                     |
| zu 4 | LV                | Zentralsystem antwortet nicht / Es herrscht keine Verbindung;<br>dem Lagerverwalter werden nur lokale Statistiken angezeigt                                                                                                                      |

## Artikel bestellen

*Aus Platzgründen wurde dieser Anwendungsfall ausgelassen*

## Artikel für automatische Verwaltung markieren

*Aus Platzgründen wurde dieser Anwendungsfall ausgelassen*

## Artikel nicht länger automatisch Verwalten

*Aus Platzgründen wurde dieser Anwendungsfall ausgelassen*

## Artikel automatisch verwalten

|   | Anwendungsfall     | Artikel automatisch verwalten                                                                                                                                             |
|---|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | Kurzbeschreibung   | In regelmäßigen Abständen ruft der Job-Scheduler diese Funktion auf. Darauf hin wird geprüft, ob ein Artikel bestellt werden muss und ggf. wird eine Bestellung ausgelöst |
|   | Beteiligte Akteure | Job-Scheduler, Lieferant, Einkäufer, Lagerverwalter                                                                                                                       |
|   | Vorbedingung       | Vordefinierte Zeit des Intervalls ist abgelaufen.<br>Mindestens ein Artikel für automatische Verwaltung markiert.                                                         |
|   | Nachbedingung      | Alle für automatische Verwaltung markierten Artikel wurden geprüft und der Einkauf wurde informiert bzw. die Bestellung wurde ausgelöst                                   |
|   | Auslöser           | Ablauf des Zeitintervalls                                                                                                                                                 |
|   | Standardszenario   |                                                                                                                                                                           |
| 1 | JS                 | Der Job-Scheduler iteriert über seine Liste, der für automatische Verwaltung markierter Artikel                                                                           |
| 2 | JS                 | prüft, ob eine Lagerposition des Artikels abgelaufen ist                                                                                                                  |
| 3 | JS                 | prüft, ob der Mindestbestand unterschritten worden ist                                                                                                                    |
|   | Erweiterungen      |                                                                                                                                                                           |

|      | Anwendungsfall    | Artikel automatisch verwalten                                                                                                                                                                                              |
|------|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| zu 2 | JS, LV            | Der Job-Scheduler stellt fest, dass Lagerpositionen des Artikels abgelaufen sind. Es wird der Lagerverwalter informiert die Artikel auszulagern und zu entsorgen und die Lagerposition wird aus dem Gesamtbestand entfernt |
| zu 3 | JS, EK, L         | Der Job-Scheduler stellt fest, dass der Mindestbestand unterschritten worden ist; die Bestellung wird beim zugeordneten Lieferanten ausgelöst und der Einkäufer informiert                                                 |
|      | Fehlersituationen |                                                                                                                                                                                                                            |
| zu 3 | JS, EK            | Der Job-Scheduler stellt fest, dass der Mindestbestand unterschritten worden ist, aber es wurde kein Lieferant zugeordnet; der Einkauf wird per E-mail über den Mangel informiert und aufgefordert zu Bestellen            |

## Log ausgeben

*Aus Platzgründen wurde dieser Anwendungsfall ausgelassen*

## Systemdesign

### Übersicht

Das Systemdesign der Lagerverwaltung für den Großhändler beschreibt die strukturelle Gliederung der Software in Komponenten und deren Interaktion. Es wird eine verteilte Architektur mit autonomen Lokalsystemen und einem zentralen Koordinationssystem entworfen, um die Anforderungen an Ausfallsicherheit, Skalierbarkeit und Echtzeit-Bestandsführung zu erfüllen.

Das System folgt einem Microservice-Ansatz, bei dem jede wesentliche Funktion (z. B. Bestandsverwaltung, Bestellmanagement, etc.) als eigenständiger Service implementiert wird. Die Kommunikation zwischen den Services erfolgt über definierte APIs (REST/HTTP) und asynchrone Nachrichten (Message Queue). Dadurch können einzelne Teile des Systems unabhängig skaliert, deployed und gewartet werden.

### Kernkomponenten

1. **Lokaler Lagerdienst (LLD)** – Pro Standort ein Service, der die lokale Lagerverwaltung (Ein-/Auslagerung, Positionsverwaltung, Verfallsdatum) übernimmt.
2. **Zentraler Bestandsdienst (ZBD)** – Führt die aggregierten Bestandsdaten aller Standorte, koordiniert Abfragen und Synchronisation.
3. **Bestellservice (BS)** – Verwaltet Bestellvorgänge (manuell/automatisch) und kommuniziert mit Lieferanten.
4. **Analytics-Service (AS)** – Berechnet Statistiken, Kennzahlen und generiert automatisierte Empfehlungen (z. B. Nachbestellung, Umschichtung).
5. **Job-Scheduler (JS)** – Führt zeitgesteuerte Aufgaben aus (automatische Bestandsprüfung, Auswertungen, Benachrichtigungen).
6. **API-Gateway** – Zentrale Eintrittspunkt für alle Client-Anfragen (Web-Frontend, Mobile Apps) und Routing zu den jeweiligen Services.
7. **Nachrichten-Broker** (z. B. RabbitMQ, Apache Kafka) – Für asynchrone Kommunikation, insbesondere bei Bestandsaktualisierungen und Ereignis-Benachrichtigungen.

### Datenbanken

- **Zentrale Datenbank** (z. B. PostgreSQL/MySQL): Speichert Stammdaten (Artikel, Lieferanten, Standorte), aggregierte Bestände, Bestellhistorien und globale Protokolle.
- **Lokale Datenbanken** (pro Standort, z. B. SQLite oder PostgreSQL): Enthalten die detaillierten Lagerpositionen, Verfallsdaten und lokale Transaktionsprotokolle.
- **Analytics-Datenbank** (z. B. TimescaleDB oder ClickHouse): Optimiert für zeitreihenbasierte Abfragen und statistische Auswertungen.

## Caching

- **Valkey** oder ähnlicher In-Memory-Cache wird eingesetzt, um häufig abgefragte Daten (z. B. Artikelstammdaten, aktuelle Bestände) zwischenspeichern und die Antwortzeiten zu verbessern.
- Cache-Strategie: LRU (Least Recently Used) mit Time-to-Live (TTL) für volatile Daten.

## API-Schnittstellen (REST)

Die APIs werden nach REST-Prinzipien definiert. Beispiele:

### Artikel anzeigen

```
get_Artikel: {ArtikelID} -> bool x string
```

Eingabe ist die Artikelnummer, Die Rückgabe ist ein Boolean, der Erfolg oder Misserfolg signalisiert, und, im Falle des Erfolgs, eine JSON-Datei mit Artikelinformationen, oder im Falle eines Misserfolgs, eine Fehlermeldung zurückgibt.

### Artikel einlagern

```
store_Artikel: {ArtikelID x int} -> bool
```

Eingabe ist die Artikelnummer und Menge, Die Rückgabe ist ein Boolean, der Erfolg oder Misserfolg signalisiert.

### Artikel auslagern

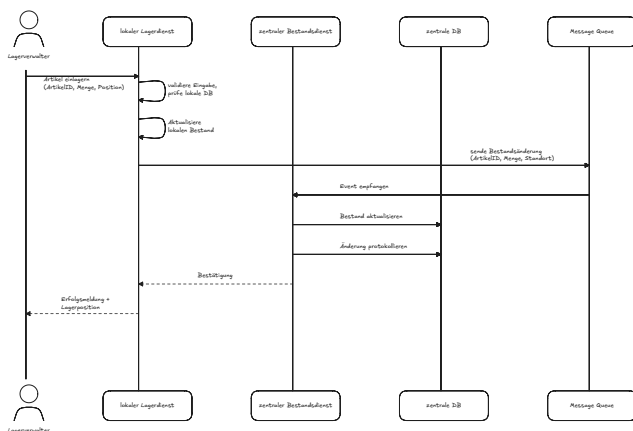
```
withdraw_Artikel: {ArtikelID x int} -> bool
```

Eingabe ist die Artikelnummer und Menge, Die Rückgabe ist ein Boolean, der Erfolg oder Misserfolg signalisiert.

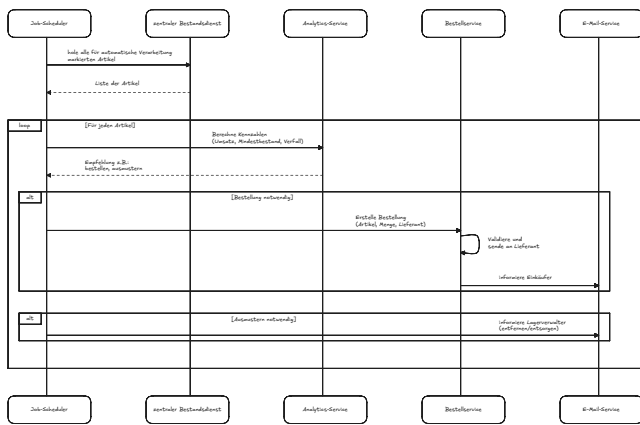
**Aus Platzgründen wurden die restlichen API-Schnittstelle ausgelassen**

## Sequenzdiagramme (Auszug)

### Artikel einlagern (mit Synchronisation)



## Automatische Bestandsprüfung durch Job-Scheduler



## Threat Modeling

### Trust Boundaries

| Grenze | Beschreibung                                        | Beteiligte Komponenten               |
|--------|-----------------------------------------------------|--------------------------------------|
| G1     | Zwischen Benutzer (LV/EK/VK) und API-Gateway        | Externes Netzwerk ↔ interner Service |
| G2     | Zwischen API-Gateway und Microservices              | API-Gateway ↔ LLD/ZBD/BS/AS          |
| G3     | Zwischen Lokalsystem und Zentralsystem              | LLD ↔ ZBD (über Netzwerk)            |
| G4     | Zwischen Services und Datenbanken                   | Services ↔ Datenbanken               |
| G5     | Zwischen System und externen Partnern (Lieferanten) | Bestellservice ↔ Lieferanten-API     |
| G6     | Zwischen Job-Scheduler und internen Services        | JS ↔ ZBD/AS/BS                       |
| G7     | Zwischen Services und Message Queue                 | Services ↔ MQ                        |

## STRIDE-Analyse pro Komponente

### 1. Lokaler Lagerdienst (LLD)

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                                                                       |
|------------------------|-----------|--------------------------------------------------------------------------------------------------------------------|
| Spoofing               | S1        | Ein Angreifer gibt sich als legitimer LLD aus und übermittelt falsche Bestandsdaten an das Zentralsystem           |
| Tampering              | T1        | Manipulation der lokalen Datenbank (Bestände, Positionen, Verfallsdaten) durch Schadsoftware oder direkten Zugriff |
| Tampering              | T2        | Manipulation der Kommunikation zwischen LLD und ZBD (Man-in-the-Middle)                                            |
| Repudiation            | R1        | Ein Lagerverwalter führt eine Ein- oder Auslagerung durch, die Aktion kann später nicht nachgewiesen werden        |
| Information Disclosure | I1        | Unbefugter Zugriff auf lokale Bestandsdaten (z. B. durch fehlende Verschlüsselung)                                 |
| Information Disclosure | I2        | Verlust von sensiblen Lagerdaten durch fehlerhafte Logausgaben                                                     |
| Denial of Service      | D1        | Überlastung des LLD durch zu viele gleichzeitige Anfragen                                                          |
| Denial of Service      | D2        | Ausfall des LLD durch gezielte Attacke oder Hardwarefehler, Lokalsystem wird autark unbrauchbar                    |
| Elevation of Privilege | E1        | Ausnutzen von Schwachstellen im LLD, um Adminrechte auf dem lokalen Server zu erlangen                             |

### 2. Zentraler Bestandsdienst (ZBD)



| STRIDE-Kategorie              | Bedrohung | Beschreibung                                                                                              |
|-------------------------------|-----------|-----------------------------------------------------------------------------------------------------------|
| <b>Spoofing</b>               | S2        | Ein Angreifer gibt sich als ZBD aus und liefert falsche aggregierte Bestandsdaten an anfragende Standorte |
| <b>Spoofing</b>               | S3        | Ein Standort gibt sich als anderer Standort aus, um Zugriff auf dessen Daten zu erhalten                  |
| <b>Tampering</b>              | T3        | Manipulation der zentralen Datenbank, um Bestände zu verfälschen (z. B. Diebstahl vertuschen)             |
| <b>Tampering</b>              | T4        | Manipulation der Synchronisationsnachrichten zwischen ZBD und LLD                                         |
| <b>Repudiation</b>            | R2        | Ein Administrator ändert kritische Daten (z. B. Mindestbestände), die Änderung ist nicht nachvollziehbar  |
| <b>Information Disclosure</b> | I3        | Unbefugter Zugriff auf die zentrale Datenbank mit allen Bestandsdaten aller Standorte                     |
| <b>Information Disclosure</b> | I4        | Abhören der Kommunikation zwischen ZBD und LLD (wichtige Geschäftsdaten im Klartext)                      |
| <b>Denial of Service</b>      | D3        | ZBD wird durch DDoS-Attacke lahmgelegt → keine standortübergreifende Bestandsabfrage möglich              |
| <b>Denial of Service</b>      | D4        | Datenbanküberlastung durch ineffiziente Abfragen oder gezielte Anfrageflut                                |
| <b>Elevation of Privilege</b> | E2        | SQL-Injection-Angriff auf die zentrale Datenbank über unsichere API-Endpunkte                             |

### 3. Bestellservice (BS)

| STRIDE-Kategorie              | Bedrohung | Beschreibung                                                                                       |
|-------------------------------|-----------|----------------------------------------------------------------------------------------------------|
| <b>Spoofing</b>               | S4        | Ein Angreifer gibt sich als Einkäufer aus und löst unberechtigte Bestellungen aus                  |
| <b>Spoofing</b>               | S5        | Ein Angreifer gibt sich als Lieferant aus und fängt Bestellungen ab (manipulierte Lieferanten-API) |
| <b>Tampering</b>              | T5        | Manipulation von Bestelldaten (Menge, Lieferadresse, Artikel) während der Übertragung              |
| <b>Tampering</b>              | T6        | Manipulation der Lieferantenstammdaten (Kontoverbindungen, Adressen)                               |
| <b>Repudiation</b>            | R3        | Ein Einkäufer bestellt Waren, bestreitet dies später (kein Protokoll)                              |
| <b>Information Disclosure</b> | I5        | Offenlegung von Lieferantenverträgen, Preisen und Konditionen an Wettbewerber                      |
| <b>Denial of Service</b>      | D5        | Bestellservice nicht erreichbar → dringende Nachbestellungen können nicht ausgelöst werden         |
| <b>Elevation of Privilege</b> | E3        | Ein regulärer Nutzer erhält Berechtigung, Bestellungen ohne Freigabe auszulösen                    |

### 4. Analytics-Service (AS)

| STRIDE-Kategorie              | Bedrohung | Beschreibung                                                                        |
|-------------------------------|-----------|-------------------------------------------------------------------------------------|
| <b>Spoofing</b>               | S6        | Angreifer gibt sich als Analytics-Service aus und liefert manipulierte Auswertungen |
| <b>Tampering</b>              | T7        | Manipulation der Berechnungslogik, um falsche Bestellvorschläge zu generieren       |
| <b>Information Disclosure</b> | I6        | Zugriff auf vertrauliche Geschäftskennzahlen (Umsatz, Marge, Absatzprognosen)       |
| <b>Information Disclosure</b> | I7        | Rückschlüsse auf Geschäftsstrategien durch Analyse der Auswertungsalgorithmen       |

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                             |
|------------------------|-----------|--------------------------------------------------------------------------|
| Denial of Service      | D6        | Analytics-Service überlastet → keine automatischen Bestellvorschläge     |
| Elevation of Privilege | E4        | Manipulation der Algorithmen zur Beeinflussung von Bestellentscheidungen |

## 5. Job-Scheduler (JS)

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                                   |
|------------------------|-----------|--------------------------------------------------------------------------------|
| Spoofing               | S7        | Angreifer triggert unberechtigt Jobs (z. B. außerplanmäßige Bestandsprüfungen) |
| Tampering              | T8        | Manipulation der Job-Konfiguration (Intervalle, Parameter)                     |
| Tampering              | T9        | Deaktivieren kritischer Jobs (z. B. Verfallsdatumskontrolle)                   |
| Information Disclosure | I8        | Einblick in Job-Planung gibt Hinweise auf Geschäftsprozesse                    |
| Denial of Service      | D7        | Job-Scheduler fällt aus → keine automatischen Prozesse mehr                    |
| Elevation of Privilege | E5        | Jobs werden mit zu hohen Berechtigungen ausgeführt (Privilegieneskalation)     |

## 6. API-Gateway

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                              |
|------------------------|-----------|---------------------------------------------------------------------------|
| Spoofing               | S8        | Angreifer umgeht Authentifizierung und greift direkt auf interne APIs zu  |
| Tampering              | T10       | Manipulation von API-Anfragen (Parameter, Header)                         |
| Information Disclosure | I9        | Offenlegung interner API-Strukturen durch zu ausführliche Fehlermeldungen |
| Denial of Service      | D8        | API-Gateway durch DDoS-Attacke lahmgelegt → gesamtes System unerreichbar  |
| Elevation of Privilege | E6        | Umgehung von Rate-Limits oder Zugriffsbeschränkungen                      |

## 7. Datenbanken (zentral & lokal)

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                                       |
|------------------------|-----------|------------------------------------------------------------------------------------|
| Spoofing               | S9        | Unberechtigte Datenbankverbindungen durch fehlende oder schwache Authentifizierung |
| Tampering              | T11       | Direkte Manipulation der Datenbankfiles (physischer Zugriff, Backup-Diebstahl)     |
| Information Disclosure | I10       | Unverschlüsselte Datenbankbackups in falschen Händen                               |
| Information Disclosure | I11       | Datenbank-Logs enthalten sensible Daten im Klartext                                |
| Denial of Service      | D9        | Datenbank füllt sich durch fehlende Archivierung/Löschung alter Daten              |
| Elevation of Privilege | E7        | Datenbank-Benutzer mit zu vielen Rechten (z. B. Anwendung nutzt Admin-Account)     |

## 8. Kommunikationswege

| STRIDE-Kategorie | Bedrohung | Beschreibung                                        |
|------------------|-----------|-----------------------------------------------------|
| Spoofing         | S10       | DNS-Spoofing leitet Anfragen an böartigen Server um |

| STRIDE-Kategorie       | Bedrohung | Beschreibung                                                |
|------------------------|-----------|-------------------------------------------------------------|
| Tampering              | T12       | Man-in-the-Middle-Angriff auf unverschlüsselte Verbindungen |
| Information Disclosure | I12       | Abhören des Netzwerkverkehrs (Sniffing)                     |
| Denial of Service      | D10       | Netzwerksegment wird überlastet oder getrennt               |

## Detailbeschreibung ausgewählter Bedrohungen

### Bedrohung T3: Manipulation der zentralen Datenbank

| Aspekt         | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kategorie      | Tampering                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Angreifer      | Externer Hacker, unzufriedener Mitarbeiter, Administrator mit böswilliger Absicht                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Beteiligte     | Zentrale DB, ZBD, ggf. andere Services                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Beschreibung   | Ein Angreifer erlangt Zugriff auf die zentrale Datenbank (direkt oder über eine Schwachstelle im ZBD) und manipuliert Bestandsdaten. Beispiel: Reduzierung der Bestände eines Artikels, um einen Diebstahl zu vertuschen, oder Erhöhung der Bestände, um eine automatische Bestellung zu verhindern.                                                                                                                                                                                                                                                                                                                                 |
| Auswirkung     | <ul style="list-style-type: none"> <li>- Falsche Bestandsführung führt zu Fehlbeständen oder Überbeständen</li> <li>- Finanzielle Verluste durch Fehlbestellungen oder Diebstahl</li> <li>- Vertrauensverlust bei Kunden (nicht lieferbare Artikel)</li> </ul>                                                                                                                                                                                                                                                                                                                                                                       |
| Gegenmaßnahmen | <ul style="list-style-type: none"> <li>- <b>Authentifizierung:</b> Starke Passwörter, Zwei-Faktor-Authentifizierung für DB-Zugriff</li> <li>- <b>Autorisierung:</b> Least-Privilege-Prinzip (Anwendung nutzt eigenen DB-User mit minimalen Rechten)</li> <li>- <b>Integrität:</b> Checksummen/Hashes für kritische Daten</li> <li>- <b>Monitoring:</b> Erkennung ungewöhnlicher Zugriffsmuster (z. B. Massenänderungen außerhalb der Geschäftszeiten)</li> <li>- <b>Verschlüsselung:</b> Verschlüsselung der Datenbank und Backups</li> <li>- <b>Audit-Logging:</b> Nachvollziehbarkeit aller Änderungen (wer, wann, was)</li> </ul> |

### Bedrohung E2: SQL-Injection auf zentrale Datenbank

| Aspekt         | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kategorie      | Elevation of Privilege / Tampering                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Angreifer      | Externer Hacker, registrierter Nutzer                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Beteiligte     | ZBD, Zentrale DB                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Beschreibung   | Ein Angreifer nutzt unsichere API-Endpunkte des ZBD aus, um SQL-Befehle in Eingabefelder einzuschleusen. Dadurch kann er beliebige Datenbankoperationen ausführen (Lesen, Ändern, Löschen).                                                                                                                                                                                                                                                                                       |
| Auswirkung     | <ul style="list-style-type: none"> <li>- Vollständiger Datenverlust oder -diebstahl</li> <li>- Übernahme des Datenbankservers</li> <li>- Zugriff auf alle Bestands-, Kunden- und Lieferantendaten</li> </ul>                                                                                                                                                                                                                                                                      |
| Gegenmaßnahmen | <ul style="list-style-type: none"> <li>- <b>Parameterized Queries / Prepared Statements:</b> Trennung von Code und Daten</li> <li>- <b>Input-Validierung:</b> Whitelist-Ansatz für alle Eingaben</li> <li>- <b>Least Privilege:</b> DB-User hat nur notwendige Rechte (kein DROP, keine Administrative Rechte)</li> <li>- <b>Web Application Firewall (WAF):</b> Erkennung und Blockierung von SQL-Injection-Versuchen</li> <li>- <b>Regelmäßige Penetrationstests</b></li> </ul> |

### Bedrohung R1: Fehlende Nachweisbarkeit von Ein-/Auslagerungen

| Aspekt         | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kategorie      | Repudiation                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Angreifer      | Lagerverwalter (mit böswilliger Absicht oder fahrlässig)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Beteiligte     | LV, LLD, ZBD                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Beschreibung   | Ein Lagerverwalter lagert Waren aus (z. B. für privaten Gebrauch) und das System protokolliert diesen Vorgang nicht ausreichend. Später kann die Tat nicht nachgewiesen werden.                                                                                                                                                                                                                                                                                                                                                                                           |
| Auswirkung     | <ul style="list-style-type: none"> <li>- Inventurdifferenzen bleiben ungeklärt</li> <li>- Keine Abschreckung gegen Diebstahl</li> <li>- Rechtliche Konsequenzen für das Unternehmen (keine Nachvollziehbarkeit bei Audits)</li> </ul>                                                                                                                                                                                                                                                                                                                                     |
| Gegenmaßnahmen | <ul style="list-style-type: none"> <li>- <b>Unveränderliches Audit-Log:</b> Jede Ein-/Auslagerung wird mit Zeitstempel, Benutzer-ID, Artikel, Menge und alter/neuer Menge protokolliert</li> <li>- <b>Digitale Signatur:</b> Logeinträge werden kryptographisch signiert, sodass sie nachträglich nicht manipuliert werden können</li> <li>- <b>Vier-Augen-Prinzip:</b> Kritische Vorgänge (z. B. Entsorgung großer Mengen) benötigen Bestätigung durch zweiten Mitarbeiter</li> <li>- <b>Regelmäßige Überprüfung</b> der Logs durch Vorgesetzte oder Revision</li> </ul> |

### Bedrohung I3: Unbefugter Zugriff auf zentrale Datenbank

| Aspekt         | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kategorie      | Information Disclosure                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Angreifer      | Externer Hacker, unzufriedener Mitarbeiter, Wettbewerber                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Beteiligte     | Zentrale DB, ZBD                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Beschreibung   | Ein Angreifer erhält Zugriff auf die zentrale Datenbank und kann alle Bestandsdaten, Lieferanteninformationen, Preise und Verkaufszahlen einsehen.                                                                                                                                                                                                                                                                                                                                                                   |
| Auswirkung     | <ul style="list-style-type: none"> <li>- Wettbewerber erhalten Einblick in Geschäftsstrategien (welche Artikel laufen gut, welche Lager sind wo)</li> <li>- Verhandlungsposition gegenüber Lieferanten geschwächt (Bekannte Konditionen)</li> <li>- Verstoß gegen Datenschutz (falls personenbezogene Daten vorhanden)</li> </ul>                                                                                                                                                                                    |
| Gegenmaßnahmen | <ul style="list-style-type: none"> <li>- <b>Verschlüsselung:</b> Verschlüsselung der Datenbank (ruhende Daten)</li> <li>- <b>Netzwerksegmentierung:</b> Datenbank nur aus internem Netz erreichbar, nicht direkt aus dem Internet</li> <li>- <b>Zugriffskontrolle:</b> Strikte Authentifizierung und Autorisierung</li> <li>- <b>Datenklassifikation:</b> Kritische Daten zusätzlich schützen (z. B. separate Verschlüsselung)</li> <li>- <b>Audit-Log:</b> Überwachung aller Zugriffe auf sensible Daten</li> </ul> |

### Bedrohung D8: DDoS-Attacke auf API-Gateway

| Aspekt       | Beschreibung                                                                                                                                                                                                                                                      |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Kategorie    | Denial of Service                                                                                                                                                                                                                                                 |
| Angreifer    | Externer Hacker, Wettbewerber (geschäftsschädigend), Erpresser                                                                                                                                                                                                    |
| Beteiligte   | API-Gateway, alle nachgelagerten Services                                                                                                                                                                                                                         |
| Beschreibung | Das API-Gateway wird mit einer Flut von Anfragen überlastet, sodass legitime Nutzer (Lagerverwalter, Verkäufer) das System nicht mehr erreichen können.                                                                                                           |
| Auswirkung   | <ul style="list-style-type: none"> <li>- Keine Ein-/Auslagerungen möglich</li> <li>- Keine Bestandsabfragen für Verkäufer (Kundenanfragen können nicht beantwortet werden)</li> <li>- Umsatzausfälle, wenn Bestellungen nicht bearbeitet werden können</li> </ul> |

| Aspekt         | Beschreibung                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Gegenmaßnahmen | <ul style="list-style-type: none"> <li>- <b>Rate Limiting</b>: Begrenzung der Anfragen pro IP/Benutzer</li> <li>- <b>Auto-Scaling</b>: Automatisches Hochskalieren der Gateway-Instanzen bei Lastspitzen</li> <li>- <b>DDoS-Schutzdienste</b>: Cloud-basierte DDoS-Mitigation (z. B. AWS Shield, Cloudflare)</li> <li>- <b>Web Application Firewall</b>: Blockierung von Bot-Traffic</li> <li>- <b>Fallback-Strategien</b>: Lokale Systeme können autark weiterarbeiten (Offline-Modus)</li> </ul> |

## Risikobewertung mit DREAD

| ID | Bedrohung                  | D  | R  | E | A  | D | Ø   | Priorität       |
|----|----------------------------|----|----|---|----|---|-----|-----------------|
| T3 | Manipulation zentrale DB   | 9  | 5  | 4 | 10 | 3 | 6,2 | Hoch            |
| E2 | SQL-Injection              | 10 | 8  | 7 | 10 | 7 | 8,4 | <b>Kritisch</b> |
| R1 | Fehlende Nachweisbarkeit   | 6  | 10 | 8 | 5  | 4 | 6,6 | Hoch            |
| I3 | Unbefugter DB-Zugriff      | 8  | 6  | 5 | 10 | 5 | 6,8 | Hoch            |
| D8 | DDoS auf API-Gateway       | 7  | 10 | 8 | 10 | 9 | 8,8 | <b>Kritisch</b> |
| T1 | Manipulation lokale DB     | 7  | 8  | 6 | 5  | 4 | 6,0 | Mittel          |
| I1 | Unbefugter Zugriff lokal   | 5  | 8  | 7 | 3  | 4 | 5,4 | Mittel          |
| D1 | Überlastung LLD            | 4  | 9  | 7 | 5  | 6 | 6,2 | Hoch            |
| E3 | Unberechtigte Bestellungen | 8  | 7  | 5 | 8  | 6 | 6,8 | Hoch            |
| T5 | Manipulation Bestelldaten  | 9  | 6  | 5 | 9  | 5 | 6,8 | Hoch            |

### Legende:

- **D** = Damage Potential (Schadenspotenzial)
- **R** = Reproducibility (Reproduzierbarkeit)
- **E** = Exploitability (Ausnutzbarkeit)
- **A** = Affected Users (Betroffene Nutzer)
- **D** = Discoverability (Auffindbarkeit)

## Spezifische Maßnahmen pro Komponente

| Komponente                      | Maßnahmen                                                                                                                                                                                                                                                 |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Lokaler Lagerdienst</b>      | <ul style="list-style-type: none"> <li>- Lokale Datenbankverschlüsselung</li> <li>- Regelmäßige Sicherungen</li> <li>- Authentifizierung aller Nutzer</li> <li>- Offline-Modus mit späterer Synchronisation</li> <li>- Zugriffsprotokollierung</li> </ul> |
| <b>Zentraler Bestandsdienst</b> | <ul style="list-style-type: none"> <li>- API mit Ratenbegrenzung</li> <li>- Eingabevalidierung (gegen SQL-Injection)</li> <li>- Mutex bei gleichzeitigen Bestandsänderungen</li> <li>- Redundante Auslegung (Cluster)</li> </ul>                          |
| <b>Bestellservice</b>           | <ul style="list-style-type: none"> <li>- Vier-Augen-Prinzip für Bestellungen &gt; X €</li> <li>- Automatische Prüfung auf Auffälligkeiten</li> <li>- Signierte Bestelldaten</li> <li>- Lieferanten-Zertifikate</li> </ul>                                 |
| <b>Analytics-Service</b>        | <ul style="list-style-type: none"> <li>- Zugriff nur für berechtigte Rollen</li> <li>- Anonymisierung von Daten für Reports</li> <li>- Getrennte Datenbank für Analysedaten</li> </ul>                                                                    |
| <b>Job-Scheduler</b>            | <ul style="list-style-type: none"> <li>- Authentifizierung der Jobs</li> <li>- Job-Konfigurationen signiert</li> <li>- Monitoring der Job-Ausführung</li> </ul>                                                                                           |

| Komponente           | Maßnahmen                                                                                                                                                                                                                           |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>API-Gateway</b>   | <ul style="list-style-type: none"> <li>- TLS-Terminierung</li> <li>- Authentifizierung aller Anfragen</li> <li>- Rate Limiting</li> <li>- Request/Response-Validierung</li> </ul>                                                   |
| <b>Datenbanken</b>   | <ul style="list-style-type: none"> <li>- Verschlüsselung ruhender Daten</li> <li>- Getrennte Benutzer pro Anwendung</li> <li>- Regelmäßige Sicherungen (verschlüsselt)</li> <li>- Zugriff nur aus definierten Netzwerken</li> </ul> |
| <b>Kommunikation</b> | <ul style="list-style-type: none"> <li>- TLS für alle externen Verbindungen</li> <li>- mTLS für interne Service-Kommunikation</li> <li>- VPN für Standortanbindungen</li> </ul>                                                     |

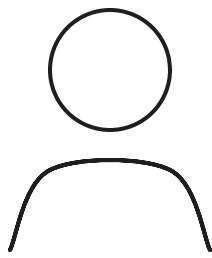
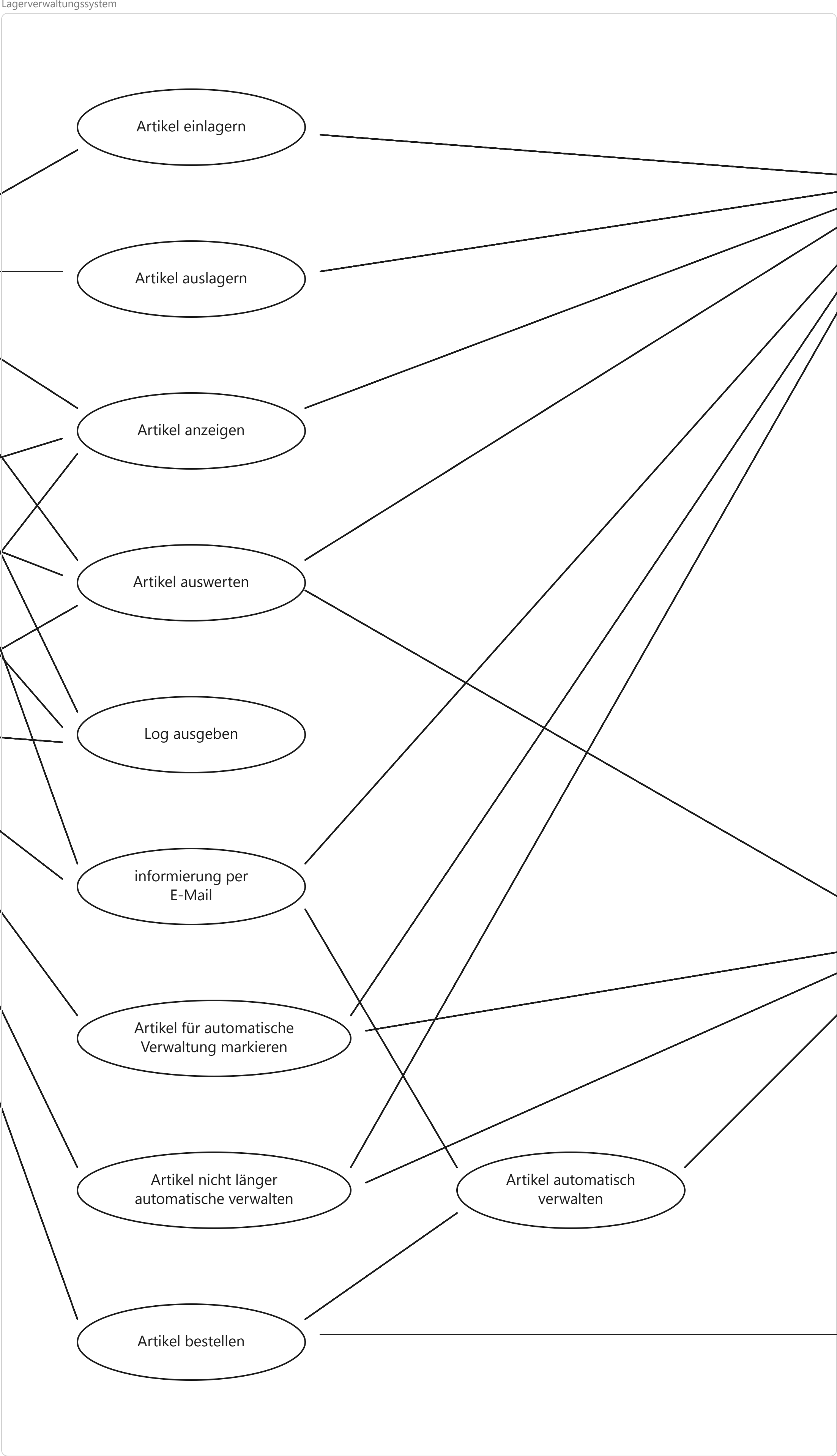
## Eidesstattliche Erklärung

Ich erkläre hiermit an Eides statt, dass ich die vorliegende Ausarbeitung selbstständig und ohne unerlaubte fremde Hilfe angefertigt, andere als die angegebenen Quellen und Hilfsmittel nicht benutzt und die den benutzten Quellen wörtlich oder inhaltlich entnommenen Stellen als solche kenntlich gemacht habe.

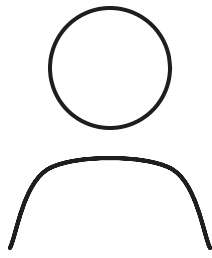
....., den .....

.....

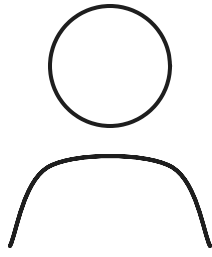
(Unterschrift)



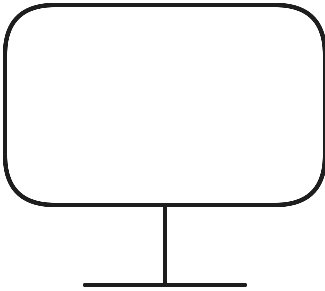
Lagerverwalter



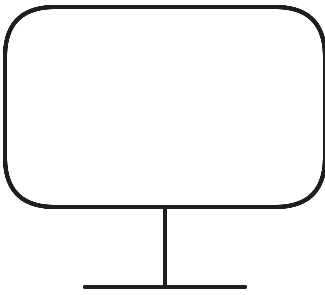
Verkäufer



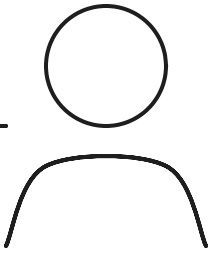
Einkäufer



Zentralsystem



Job-Scheduler



Lieferant



